

Clase 002 — El panorama de amenazas moderno: actores, motivaciones y Cyber Kill Chain

Parte: **0 — Fundamentos y prerequisites** · Fuente: *Lockheed Martin, Intelligence-Driven Computer Network Defense (Kill Chain)* 🕒 Duración estimada: **90 min** · Nivel: **Fundamentos**

Objetivo

Entender quién ataca, por qué lo hace y cómo se estructura un ataque dirigido de principio a fin. Al terminar podrás clasificar a un adversario por sus capacidades y motivaciones, y descomponer un incidente en las fases de la Cyber Kill Chain para saber en qué punto detectarlo o cortarlo.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Clasificar** actores de amenaza por tipo, capacidad y motivación.
2. **Describir** las siete fases de la Cyber Kill Chain de Lockheed Martin.
3. **Ubicar** controles defensivos en cada fase de la cadena.
4. **Diferenciar** amenaza oportunista de amenaza persistente avanzada (APT).
5. **Interpretar** informes de *threat intelligence* con vocabulario correcto.

Temas

#	Tema	Por qué importa
1	Tipos de actor	Un script kiddie y un Estado-nación exigen defensas distintas
2	Motivaciones	Financiera, geopolítica, hacktivismo, insider
3	Cyber Kill Chain	Modelo para anticipar y romper el ataque
4	APT	Adversarios persistentes con recursos y objetivos
5	Ransomware moderno	Doble extorsión y RaaS como industria
6	Insider threat	El riesgo desde dentro, a menudo subestimado
7	Threat intelligence	Cómo se produce y consume información de amenazas
8	IoC vs. TTP	Indicadores efímeros vs. comportamientos duraderos

Definiciones y características

- **Actor de amenaza:** entidad (persona o grupo) que puede causar daño. Se caracteriza por su capacidad, recursos y motivación.

- **APT (Advanced Persistent Threat)**: adversario sofisticado y persistente, normalmente estatal o crimen organizado. Clave: prioriza el sigilo y la permanencia sobre la rapidez.
- **Cyber Kill Chain**: modelo de 7 fases (reconocimiento → armamento → entrega → explotación → instalación → C2 → acciones sobre objetivos). Clave: romper una sola fase frustra el ataque.
- **IoC (Indicator of Compromise)**: evidencia concreta de un ataque (hash, IP, dominio). Clave: efímero, fácil de rotar por el atacante.
- **TTP (Tácticas, Técnicas y Procedimientos)**: cómo opera un adversario. Clave: más estable que los IoC, base de la caza de amenazas.
- **Ransomware como servicio (RaaS)**: modelo de negocio donde operadores alquilan el malware a afiliados. Clave: profesionaliza y escala el cibercrimen.

Herramientas y preparación

Consulta fuentes reales de *threat intelligence*: **MITRE ATT&CK** (<https://attack.mitre.org>), el **catálogo CISA KEV** de vulnerabilidades explotadas, y los informes anuales públicos (Verizon DBIR, ENISA Threat Landscape). Crea una cuenta gratuita en **AlienVault OTX** o revisa feeds abiertos para ver IoC reales. No se requiere laboratorio ofensivo.

Laboratorio guiado (ejercicio aplicado)

1. Elige un incidente público bien documentado (por ejemplo, un caso de ransomware o de compromiso de cadena de suministro descrito por CISA).
2. **Mapea la Kill Chain**: para cada una de las 7 fases, escribe qué hizo el atacante en ese incidente. Si falta información, márcalo como "desconocido".
3. **Perfil del actor**: clasifica al adversario (tipo, motivación probable, nivel de recursos). Justifica con evidencia del informe.
4. **Controles por fase**: junto a cada fase, escribe un control defensivo que la habría cortado (p. ej., filtrado de correo en "entrega", EDR en "instalación", bloqueo de salida en "C2").
5. **IoC vs. TTP**: extrae del informe 3 IoC y 3 TTP. Reflexiona: ¿cuáles caducan antes?
6. **Correlación ATT&CK**: identifica al menos 3 técnicas de MITRE ATT&CK presentes y anota sus IDs (formato Txxxx).

Ejercicios

1. Ordena de menor a mayor sofisticación: hacktivista, script kiddie, APT estatal, insider malicioso.
2. Explica por qué "romper la cadena" en la fase de entrega es más barato que hacerlo en "acciones sobre objetivos".
3. Da un ejemplo de IoC y uno de TTP para una campaña de phishing.
4. ¿Qué motivación tiene un grupo de ransomware? ¿Y una APT estatal? Contrasta objetivos.
5. Investiga un grupo APT documentado en ATT&CK y resume sus TTP principales.
6. Diseña una tabla de detección: fase de la Kill Chain → señal observable → herramienta que la capta.

Reto verificable

Elabora un informe de una página tipo *threat profile* sobre un actor o campaña real: incluye clasificación del actor, mapeo completo de la Kill Chain, al menos 5 técnicas ATT&CK con sus IDs, y una recomendación defensiva por cada fase.

Criterio de aceptación: cada técnica citada existe en la matriz oficial de ATT&CK (ID verificable), y cada fase de la Kill Chain tiene al menos un control defensivo asociado. Un compañero debe poder validar los IDs contra attack.mitre.org.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Llamar "APT" a cualquier ataque	APT implica persistencia y recursos altos; la mayoría de ataques son oportunistas. Reserva el término.
Bloquear solo IoC y sentirse seguro	Los IoC rotan en horas; caza también por TTP y comportamiento.
Ver la Kill Chain como lineal e inviolable	Los ataques modernos iteran y saltan fases; úsala como guía, no como dogma.
Ignorar el insider threat	No todo ataque viene de fuera; controles internos y segregación de funciones importan.
Confundir motivación con capacidad	Un actor muy motivado puede ser poco capaz y viceversa; evalúa ambas.

? Preguntas frecuentes

? **¿La Kill Chain de Lockheed sigue vigente frente a ATT&CK?** Sí, son complementarias: la Kill Chain da la vista macro por fases; ATT&CK detalla las técnicas concretas dentro de cada fase.

? **¿Por qué el ransomware es tan común hoy?** Porque el modelo RaaS bajó la barrera de entrada y la doble extorsión (cifrar + filtrar) aumentó la presión de pago.

? **¿Threat intelligence es solo para grandes empresas?** No. Incluso una pyme puede consumir feeds gratuitos (CISA KEV, OTX) para priorizar parches sobre lo que se explota activamente.

? **¿Un insider siempre es malicioso?** No: muchos incidentes internos son negligentes (clic en phishing, mala configuración), no intencionados. Ambos requieren control.

🔗 Referencias

- Lockheed Martin, *Cyber Kill Chain* — <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>
- MITRE ATT&CK — <https://attack.mitre.org/>
- CISA Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- Verizon Data Breach Investigations Report (DBIR) — <https://www.verizon.com/business/resources/reports/dbir/>

➡ Siguiente clase

Clase 003 - Frameworks de seguridad: NIST CSF, ISO 27001, MITRE ATT&CK y Diamond Model